

HRMS Mobile Authentication — API Documentation (v1)

Base URL (dev): `http://localhost:5000` · **Auth base path:** `/api/v1/auth` · **Version:** v1

Login accepts **Mobile number, Employee ID, or Email**. Authentication is OTP-based.

The access token is a standard **Bearer JWT** accepted by every protected HRMS API.

Temporary OTP (development): The app must always show the OTP screen. The backend

currently accepts **any 4-digit OTP** and sends **no SMS** (`OTP_MODE=development`).

Switching the backend to `OTP_MODE=production` requires **no Flutter code changes**.

Endpoints

1. `POST /api/v1/auth/login`
2. `POST /api/v1/auth/verify-otp`
3. `POST /api/v1/auth/refresh`
4. `POST /api/v1/auth/logout`
5. `GET /api/v1/auth/me`

Login — generate OTP session

Endpoint	<code>POST /api/v1/auth/login</code>
Method	POST
Authorization	None (public)

Required headers

Content-Type: application/json

Request body

```
{
  "mobile": "9876543210"
}
```

Validation rules

- Send exactly ONE identifier: `mobile` , `employeeId` , or `email` .
- The identifier must belong to an existing, active account.

Success response — 200 OK

```
{
  "success": true,
  "message": "OTP Generated",
  "otpRequired": true,
  "otpLength": 4,
  "sessionId": "a1b2c3d4e5f6",
  "expiresInMinutes": 5,
  "otpMode": "development",
  "devOtp": "1111",
  "devNote": "OTP_MODE=development – enter any 4-digit code to log in. No SMS is sent."
}
```

Error responses

400 IDENTIFIER_REQUIRED

```
{
  "success": false,
  "code": "IDENTIFIER_REQUIRED",
  "message": "Provide a mobile number, employee ID, or email."
}
```

404 USER_NOT_FOUND

```
{
  "success": false,
  "code": "USER_NOT_FOUND",
  "message": "No account is registered for that identifier."
}
```

403 ACCOUNT_INACTIVE

```
{
  "success": false,
  "code": "ACCOUNT_INACTIVE",
  "message": "Account inactive. Please contact your administrator."
}
```

403 BRANCH_DISABLED

```
{
  "success": false,
  "code": "BRANCH_DISABLED",
  "message": "Branch disabled. Please contact your administrator."
}
```

HTTP status codes

- 200 OK
- 400 Bad Request
- 403 Forbidden
- 404 Not Found
- 500 Server Error

Example cURL

```
curl -s -X POST http://localhost:5000/api/v1/auth/login \
-H 'Content-Type: application/json' \
-d '{"mobile": "9876543210"}'
```

Example Flutter (Dio)

```
// Using package:dio
final dio = Dio(BaseOptions(baseUrl: 'http://localhost:5000'));

Future<String> login(String identifier) async {
  // Send whichever field applies: mobile / employeeId / email
  final res = await dio.post('/api/v1/auth/login', data: {'mobile': identifier});
  return res.data['sessionId'] as String; // navigate to OTP screen
}
```

Notes

- In development the response includes `devOtp` and any 4-digit code will verify.
- Persist the returned `sessionId` and pass it to `/verify-otp`.
- The OTP screen must always be shown, even though dev mode accepts any code.

Verify OTP — issue tokens

Endpoint	POST /api/v1/auth/verify-otp
Method	POST
Authorization	None (public)

Required headers

```
Content-Type: application/json
```

Request body

```
{
  "sessionId": "a1b2c3d4e5f6",
  "otp": "1234"
}
```

Validation rules

- `sessionId` must be the value returned by /login.
- `otp` must be a numeric string of length `otpLength` (default 4).
- A session expires after ~5 minutes and after 5 failed attempts.

Success response — 200 OK

```
{
  "success": true,
  "accessToken": "eyJhbGciOi...",
  "refreshToken": "eyJhbGciOi...",
  "tokenType": "Bearer",
  "expiresIn": 3600,
  "refreshExpiresIn": 2592000,
  "user": {
    "id": 1,
    "userId": 1,
    "employeeRecordId": 12,
    "employeeId": "VE-AHM-001",
    "employeeCode": "VE-AHM-001",
    "firstName": "Om",
    "lastName": "Patel",
    "name": "Om Patel",
    "email": "abc@gmail.com",
```

```

"mobile": "9876543210",
"company": {
  "id": 2,
  "name": "Vision Enterprise"
},
"branch": {
  "id": 5,
  "name": "Ahmedabad"
},
"department": "IT",
"designation": "Developer",
"role": "Employee",
"permissions": [
  "attendance.view",
  "attendance.mark",
  "leave.create"
],
"permissionMatrix": {
  "attendance": {
    "view": true,
    "mark": true
  },
  "leave": {
    "create": true
  }
},
"moduleAccess": {
  "attendance": true,
  "leave": true
},
"profileImage": "",
"themePreference": null,
"languagePreference": null,
"isFirstLogin": false,
"isPasswordCreated": true
}
}

```

Error responses

400 INVALID_SESSION

```

{
  "success": false,
  "code": "INVALID_SESSION",
  "message": "Invalid or unknown session."
}

```

400 SESSION_CONSUMED

```

{
  "success": false,
  "code": "SESSION_CONSUMED",

```

```
"message": "This OTP session was already used. Please request a new code."
}
```

400 OTP_EXPIRED

```
{
  "success": false,
  "code": "OTP_EXPIRED",
  "message": "Your code has expired. Please request a new one."
}
```

400 INVALID_OTP

```
{
  "success": false,
  "code": "INVALID_OTP",
  "message": "Enter any 4-digit code."
}
```

429 TOO_MANY_ATTEMPTS

```
{
  "success": false,
  "code": "TOO_MANY_ATTEMPTS",
  "message": "Too many incorrect attempts. Please request a new code."
}
```

HTTP status codes

- 200 OK
- 400 Bad Request
- 429 Too Many Requests
- 500 Server Error

Example cURL

```
curl -s -X POST http://localhost:5000/api/v1/auth/verify-otp \
-H 'Content-Type: application/json' \
-d '{"sessionId":"a1b2c3d4e5f6","otp":"1234"}'
```

Example Flutter (Dio)

```
Future<void> verifyOtp(String sessionId, String otp) async {
  final res = await dio.post('/api/v1/auth/verify-otp',
    data: {'sessionId': sessionId, 'otp': otp});
}
```

```
final data = res.data;
await storage.write(key: 'accessToken', value: data['accessToken']);
await storage.write(key: 'refreshToken', value: data['refreshToken']);
// data['user'] holds the full profile
}
```

Notes

- Store `accessToken` and `refreshToken` securely (`flutter_secure_storage`).
- The `user` object is the full profile — see `Models/User_Model.json`.
- `expiresIn` is in seconds; refresh before it elapses or on a 401.

Refresh — new access token

Endpoint	POST <code>/api/v1/auth/refresh</code>
Method	POST
Authorization	None (refresh token in body)

Required headers

```
Content-Type: application/json
```

Request body

```
{
  "refreshToken": "eyJhbGciOi..."
}
```

Validation rules

- `refreshToken` must be the unexpired token from `/verify-otp`.

Success response — 200 OK

```
{
  "success": true,
  "accessToken": "eyJhbGciOi...",
  "tokenType": "Bearer",
```

```
"expiresIn": 3600
}
```

Error responses

400 REFRESH_TOKEN_REQUIRED

```
{
  "success": false,
  "code": "REFRESH_TOKEN_REQUIRED",
  "message": "A refresh token is required."
}
```

401 REFRESH_TOKEN_INVALID

```
{
  "success": false,
  "code": "REFRESH_TOKEN_INVALID",
  "message": "Your session has expired. Please sign in again."
}
```

403 ACCOUNT_INACTIVE

```
{
  "success": false,
  "code": "ACCOUNT_INACTIVE",
  "message": "Account inactive."
}
```

HTTP status codes

- 200 OK
- 400 Bad Request
- 401 Unauthorized
- 403 Forbidden

Example cURL

```
curl -s -X POST http://localhost:5000/api/v1/auth/refresh \
-H 'Content-Type: application/json' \
-d '{"refreshToken":"eyJhbGciOiI..."}'
```

Example Flutter (Dio)

```
Future<String> refresh(String refreshToken) async {
  final res = await dio.post('/api/v1/auth/refresh',
    data: {'refreshToken': refreshToken});
  final newAccess = res.data['accessToken'] as String;
  await storage.write(key: 'accessToken', value: newAccess);
  return newAccess;
}
```

Notes

- Call this transparently inside a Dio interceptor on 401, then retry the request.
- If refresh returns 401, route the user back to the Login screen.

Logout

Endpoint	POST /api/v1/auth/logout
Method	POST
Authorization	Bearer access token

Required headers

```
Content-Type: application/json
Authorization: Bearer <accessToken>
```

Request body

None.

Validation rules

- Send the current access token in the Authorization header.

Success response — 200 OK

```
{
  "success": true,
  "message": "Logged out."
}
```

Error responses

401 UNAUTHORIZED

```
{
  "success": false,
  "code": "UNAUTHORIZED",
  "message": "Not authorized, no token provided"
}
```

HTTP status codes

- 200 OK
- 401 Unauthorized

Example cURL

```
curl -s -X POST http://localhost:5000/api/v1/auth/logout \
-H 'Authorization: Bearer <accessToken>'
```

Example Flutter (Dio)

```
Future<void> logout(String accessToken) async {
  await dio.post('/api/v1/auth/logout',
    options: Options(headers: {'Authorization': 'Bearer $accessToken'}));
  await storage.deleteAll();
}
```

Notes

- Tokens are stateless JWTs — after calling logout, clear them from local storage.
- Any outstanding OTP sessions for the user are invalidated server-side.

Get Profile (me)

Endpoint	GET /api/v1/auth/me
Method	GET
Authorization	Bearer access token

Required headers

```
Content-Type: application/json
Authorization: Bearer <accessToken>
```

Request body

None.

Validation rules

- Send a valid, unexpired access token in the Authorization header.

Success response — 200 OK

```
{
  "success": true,
  "user": {
    "id": 1,
    "userId": 1,
    "employeeRecordId": 12,
    "employeeId": "VE-AHM-001",
    "employeeCode": "VE-AHM-001",
    "firstName": "Om",
    "lastName": "Patel",
    "name": "Om Patel",
    "email": "abc@gmail.com",
    "mobile": "9876543210",
    "company": {
      "id": 2,
      "name": "Vision Enterprise"
    },
    "branch": {
      "id": 5,
      "name": "Ahmedabad"
    },
    "department": "IT",
    "designation": "Developer",
    "role": "Employee",
    "permissions": [
      "attendance.view",
      "attendance.mark",
      "leave.create"
    ],
    "permissionMatrix": {
      "attendance": {
        "view": true,
        "mark": true
      },
      "leave": {
```

```

        "create": true
      },
    },
    "moduleAccess": {
      "attendance": true,
      "leave": true
    },
    "profileImage": "",
    "themePreference": null,
    "languagePreference": null,
    "isFirstLogin": false,
    "isPasswordCreated": true
  }
}

```

Error responses

401 UNAUTHORIZED

```

{
  "success": false,
  "code": "UNAUTHORIZED",
  "message": "Not authorized, token failed"
}

```

404 USER_NOT_FOUND

```

{
  "success": false,
  "code": "USER_NOT_FOUND",
  "message": "Account not found."
}

```

HTTP status codes

- 200 OK
- 401 Unauthorized
- 404 Not Found

Example cURL

```

curl -s http://localhost:5000/api/v1/auth/me \
-H 'Authorization: Bearer <accessToken>'

```

Example Flutter (Dio)

```
Future<Map<String, dynamic>> getMe(String accessToken) async {
  final res = await dio.get('/api/v1/auth/me',
    options: Options(headers: {'Authorization': 'Bearer $accessToken'}));
  return res.data['user'] as Map<String, dynamic>;
}
```

Notes

- Call on app start (after reading a stored token) to hydrate the user state.
- Returns the same `user` shape as `/verify-otp`.

Common error envelope

```
{ "success": false, "code": "USER_NOT_FOUND", "message": "No account is registered for that iden
```

HTTP	code
400	IDENTIFIER_REQUIRED, INVALID_SESSION, SESSION_CONSUMED, OTP_EXPIRED, INVALID_OTP, REFRESH_TOKEN_REQUIRED
401	UNAUTHORIZED, REFRESH_TOKEN_INVALID
403	ACCOUNT_INACTIVE, BRANCH_DISABLED
404	USER_NOT_FOUND
429	TOO_MANY_ATTEMPTS
500	SERVER_ERROR